

# Compliance Crosswalk

NIST CSF 2.0, CIS Controls v8, and SOC 2 Trust Services Criteria

## Purpose

This crosswalk demonstrates how one control activity can support multiple frameworks. Mappings are illustrative and should be validated against the organization's selected framework versions and scope.

## Framework Crosswalk

| Control Activity              | NIST CSF 2.0       | CIS Controls v8 | SOC 2 TSC    | Evidence                                                          |
|-------------------------------|--------------------|-----------------|--------------|-------------------------------------------------------------------|
| Identity lifecycle management | PR.AA-01, PR.AA-05 | 5, 6            | CC6.1, CC6.2 | Approvals, role matrix, provisioning and termination records      |
| MFA and privileged access     | PR.AA-03, PR.AA-05 | 6               | CC6.1, CC6.3 | MFA configuration, PAM logs, privileged review                    |
| Vulnerability management      | ID.RA-01, PR.PS-02 | 7               | CC7.1        | Scan reports, remediation tickets, SLA metrics                    |
| Security awareness            | PR.AT-01           | 14              | CC2.2, CC2.3 | Training completion and phishing results                          |
| Logging and monitoring        | DE.CM-01, DE.AE-02 | 8, 13           | CC7.2, CC7.3 | SIEM alerts, review records, escalation metrics                   |
| Incident response             | RS.MA-01, RS.AN-03 | 17              | CC7.4, CC7.5 | Plan, incident records, tabletop results                          |
| Backup and recovery           | PR.IR-04, RC.RP-01 | 11              | A1.2, A1.3   | Backup logs, restore testing, recovery results                    |
| Third-party risk              | GV.SC-06, GV.SC-07 | 15              | CC9.2        | Vendor inventory, assessments, contracts, residual-risk approvals |

## How to Use the Crosswalk

Start with the organization's control language, then map each control to applicable framework outcomes. Maintain version, scope, rationale, owner, and evidence references. Avoid treating a crosswalk as proof of compliance; operating effectiveness must still be tested.

## Example Control Statement

**AC-01:** The organization approves access based on job responsibilities, enforces MFA for sensitive access, removes access promptly after termination, and performs quarterly access reviews. This single control supports identity-related requirements across NIST CSF, CIS Controls, and SOC 2.